Microsoft Certified: Security Operations Analyst Associate

Course

Defend against cyberthreats with Microsoft's security operations platform

---

Module 1

Mitigate threats using Microsoft Defender XDR

Modules in this learning path

COURSE 5

Safeguard your environment with Microsoft Defender for Identity

Introduction to Microsoft Defender for Identity

Microsoft Defender for Identity is a cloud-based security solution that monitors identity signals from on-premises Active Directory, Microsoft Entra ID, and other identity providers to identify, detect, and investigate advanced threats, compromised identities, and malicious insider actions directed at your organization.



Microsoft Defender for Identity provides the following benefits:

Proactively assess identity security posture and surface weaknesses before they're exploited

Monitor users, entity behavior, and activities with learning-based analytics

Protect user identities and credentials stored in Active Directory and Microsoft Entra ID

Identify and investigate suspicious user activities and advanced attacks throughout the kill chain

Provide clear incident information on a simple timeline for fast triage

Monitor and profile user behavior and activities

Microsoft Defender for Identity monitors and analyzes user activities and information across your network, such as permissions and group membership. It then creates a behavioral baseline for each user. Microsoft Defender for Identity then identifies anomalies with adaptive built-in intelligence, giving you insights into suspicious activities and events, revealing the advanced threats, compromised users, and insider threats facing your organization. Microsoft Defender for Identity's proprietary sensors monitor organizational domain controllers, providing a comprehensive view for all user activities from every device.



Proactively assess identity security posture

Microsoft Defender for Identity evaluates your identity configurations and continuously surfaces weaknesses before attackers can exploit them. Posture assessments are reflected in Microsoft Secure Score, giving you measurable, actionable recommendations to harden your environment. Lateral movement path analysis shows exactly how an attacker could traverse your environment to reach sensitive accounts, so you can close those paths proactively.

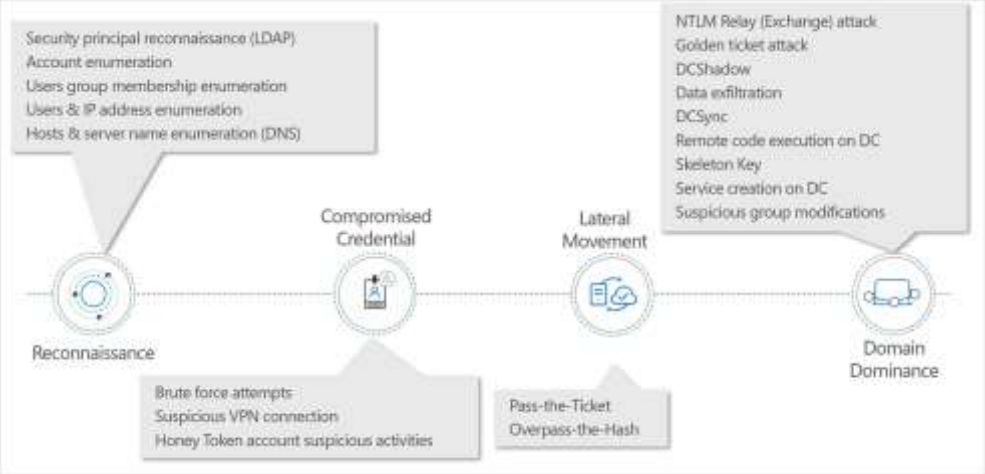
Protect user identities and reduce the attack surface

Microsoft Defender for Identity provides you invaluable insights on identity configurations and suggested security best-practices. Through security reports and user profile analytics, Microsoft Defender for Identity helps dramatically reduce your organizational attack surface, making it harder to compromise user credentials and advance an attack. Microsoft Defender for Identity's visual Lateral Movement Paths help you quickly understand exactly how an attacker can move laterally inside your organization to compromise sensitive accounts and helps preventing those risks in advance. Microsoft Defender for Identity security reports help identify users and devices that authenticate using clear-text passwords and provide other insights to improve your organizational security posture and policies.



Identify suspicious activities and advanced attacks across the cyber-attack kill-chain

Typically, attacks are launched against any accessible entity, such as a low-privileged user, and then quickly move laterally until the attacker gains access to valuable assets – such as sensitive accounts, domain administrators, and highly sensitive data. Microsoft Defender for Identity has a large range of detections across the Kill-chain from reconnaissance through to compromised credentials to lateral movements and domain dominance.



For example, in the reconnaissance stage, LDAP reconnaissance is used by attackers to gain critical information about the domain environment. Information that helps attackers map the domain structure, and identify privileged accounts for use later. This detection is triggered based on computers performing suspicious LDAP enumeration queries or queries targeting sensitive groups.

Brute force attacks are a common way to compromise credentials. This is when an attacker attempts to authenticate with multiple passwords on different accounts until a correct password is found or by using one password in a large-scale password spray that works for at least one account. Once found, the attacker logs in using the authenticated account. Microsoft Defender for Identity can detect this when it notices multiple authentication failures occurring using Kerberos, NTLM, or use of a password spray.

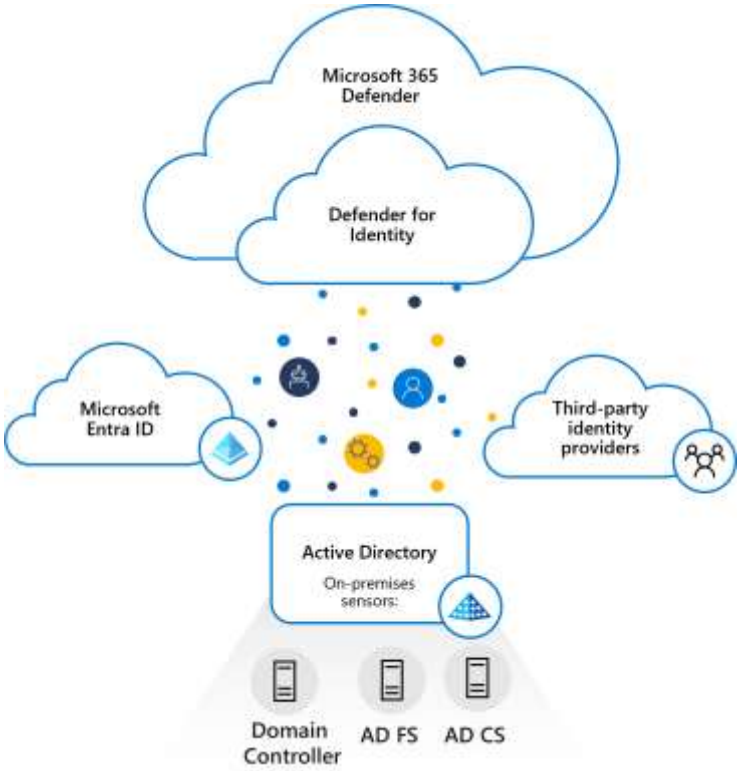
The next stage is when attackers attempt to move laterally through your environment, using pass-the-ticket, for example. Pass-the-ticket is a lateral movement technique in which attackers steal a Kerberos ticket from one computer and use it to gain access to another computer by reusing the stolen ticket. In this detection, a Kerberos ticket is being used on two (or more) different computers.

Ultimately, attackers want to establish domain dominance. One method, for example is the DCShadow attack. This attack is designed to change directory objects using malicious replication. This attack can be performed from any machine by creating a rogue domain controller using a replication process. If this occurs, Microsoft Defender for Identity triggers an alert when a machine in the network tries to register as a rogue domain controller.

This isn't the complete set of detections, but it shows the breadth of detections Microsoft Defender for Identity covers.

Configure Microsoft Defender for Identity sensors

The following diagram shows the Microsoft Defender for Identity architecture. In this unit, we discuss how to configure the Microsoft Defender for Identity Sensor.



When installed directly on your domain controllers, the Microsoft Defender for Identity sensor accesses the event logs it requires directly from the domain controller. After the logs and network traffic are parsed by the sensor, Microsoft Defender for Identity sends only the parsed information to the Microsoft Defender for Identity cloud service (only a percentage of the logs are sent).

The Microsoft Defender for Identity sensor has the following core functionality:

Capture and inspect domain controller network traffic (local traffic of the domain controller)

Receive Windows events directly from the domain controllers

Receive RADIUS accounting information from your VPN provider

Retrieve data about users and computers from the Active Directory domain

Perform resolution of network entities (users, groups, and computers)

Transfer relevant data to the Microsoft Defender for Identity cloud service

View and configure sensor settings

After the Defender for Identity sensor is installed, do the following to view and configure Defender for Identity sensor settings:

In the Microsoft Defender portal (https://security.microsoft.com), go to Settings > Identities. In the left sidebar, under Deployment, select On-premises, then select the Sensors tab.

The Sensors tab displays all of your Defender for Identity sensors, listing the following details per sensor:

Sensor name

Sensor type (domain controller sensor, AD FS sensor, standalone sensor, Entra Connect sensor, or AD CS sensor)

Sensor domain membership

Sensor version number

Whether updates should be delayed

Migration state (indicates eligibility for upgrade from sensor v2.x to v3.x)

Sensor service status

Sensor status

Sensor health status

The number of health issues

When the sensor was created

Select Filters to select the filters you want visible. Then use the displayed filters to determine which sensors to display.

Select a sensor to show a details pane with more information about the sensor and its health status.

Scroll down and select Manage sensor to show a pane where you can configure sensor details.

Configure the following sensor details:

Name	Description
Description	Optional. Enter a description for the Defender for Identity sensor.
Domain Controllers (FQDN)	Required for the Defender for Identity standalone sensors and sensors installed on AD FS / AD CS servers, and can't be modified for the Defender for Identity sensor. Enter the complete FQDN of your domain controller and select the plus sign to add it to the list. For example, **DC1.domain1.test.local**. For any servers you define in the **Domain Controllers** list: - All domain controllers whose traffic is being monitored via port mirroring by the Defender for Identity standalone sensor must be listed in the **Domain Controllers** list. If a domain controller isn't listed in the **Domain Controllers** list, detection of suspicious activities might not function as expected. - At least one domain controller in the list should be a global catalog. This enables Defender for Identity to resolve computer and user objects in other domains in the forest.
Capture Network adapters	Required. For Defender for Identity sensors, all network adapters that are used for communication with other computers in your organization. For Defender for Identity standalone sensor on a dedicated server, select the network adapters that are configured as the destination mirror port. These network adapters receive the mirrored domain controller traffic.

On the Sensors page, select Export to export a list of your sensors to a .csv file.

Validate installations

Use the following procedures to validate your Defender for Identity sensor installation.

Note

If you're installing on an AD FS or AD CS server, you use a different set of validations.

Validate successful deployment

To validate that the Defender for Identity sensor has been successfully deployed:

Check that the Azure Advanced Threat Protection sensor service is running on your sensor machine. After you save the Defender for Identity sensor settings, it might take a few seconds for the service to start.

If the service doesn't start, review the Microsoft.Tri.sensor-Errors.log file, located by default at %programfiles%\Azure Advanced Threat Protection sensor\<sensor version>\Logs, where <sensor version> is the version you deployed.

Verify security alert functionality

This section describes how you can verify that security alerts are being triggered as expected.

When using the examples in the following steps, make sure to replace contosodc.contoso.azure and contoso.azure with the FQDN of your Defender for Identity sensor and domain name respectively.

On a member-joined device, open a command prompt and enter nslookup.

Enter server and the FQDN or IP address of the domain controller where the Defender for Identity sensor is installed. For example: server contosodc.contoso.azure.

Enter ls -d contoso.azure.

Repeat the previous two steps for each sensor you want to test.

Access the device details page for the computer you ran the connectivity test from, such as from the Devices page, by searching for device name, or from elsewhere in the Defender portal.

On the device details tab, select the Timeline tab to view the following activity:

Events: DNS queries performed to a specified domain name

Action type: MdiDnsQuery

If the domain controller or AD FS / AD CS that you're testing is the first sensor you deployed, wait at least 15 minutes before verifying any logical activity for that domain controller, allowing the database backend to complete the initial microservice deployments.

Verify latest available sensor version

The Defender for Identity version is updated frequently. Check for the latest version in the Microsoft Defender XDR Settings > Identities > About page.

Review compromised accounts or data

Microsoft Defender for Identity security alerts explain suspicious activities detected by Microsoft Defender for Identity sensors on your network, and the actors and computers involved in each threat. Alert evidence lists contain direct links to the involved users and computers, to help make your investigations easy and direct.

Microsoft Defender for Identity security alerts are divided into the following categories or phases, like the phases seen in a typical cyber-attack kill chain:

Reconnaissance phase alerts

Compromised credential phase alerts

Lateral movement phase alerts

Domain dominance phase alerts

Exfiltration phase alerts

Each Microsoft Defender for Identity security alert includes:

Alert title. Official Microsoft Defender for Identity name of the alert.

Description. Brief explanation of what happened.

Evidence. Other relevant information and related data about what happened to help in the investigation process.

Excel download. Detailed Excel download report for analysis



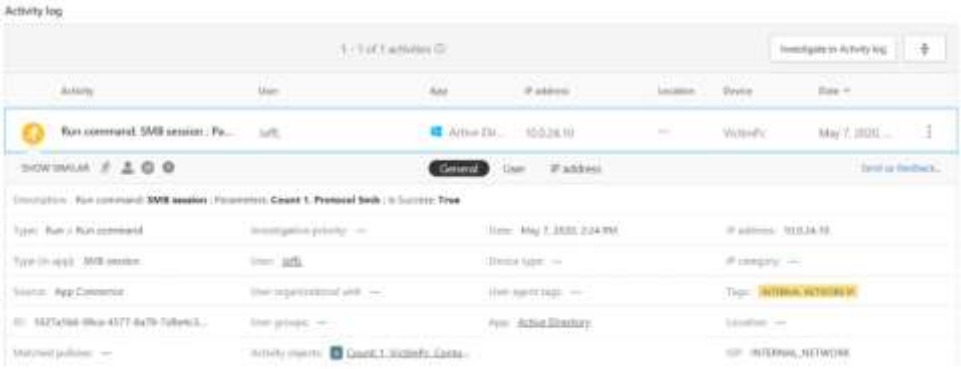
All alerts from Microsoft Defender for Identity are surfaced in the unified Microsoft Defender portal at Incidents & alerts > Alerts. The alert queue brings together signals from across Microsoft Defender XDR workloads, including Defender for Identity, Defender for Cloud Apps, and Defender for Endpoint, into a single investigation surface.

The following scenario describes an investigation into an attacker gaining administrator access to the domain controller and compromising the Active Directory domain and forest.

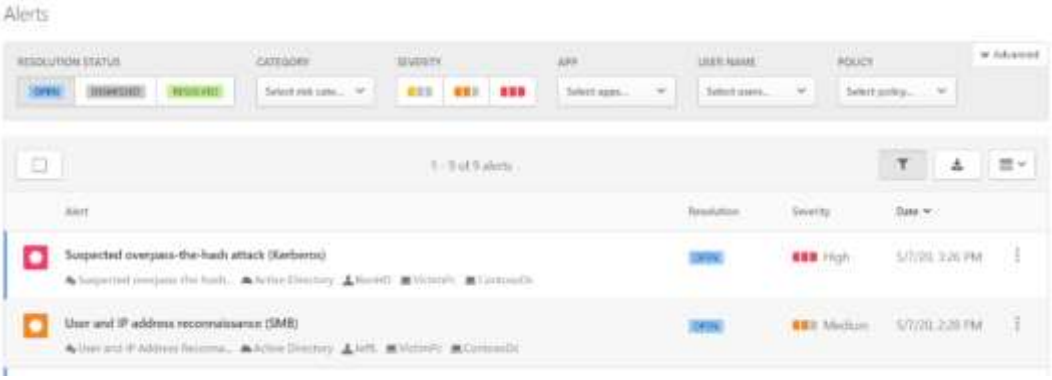
The first alert we notice in the Microsoft Defender portal shows User and IP address reconnaissance (SMB). Selecting this alert, we see (under Description) that a user was able to learn the IP addresses of two accounts by enumerating SMB sessions on the domain controller.



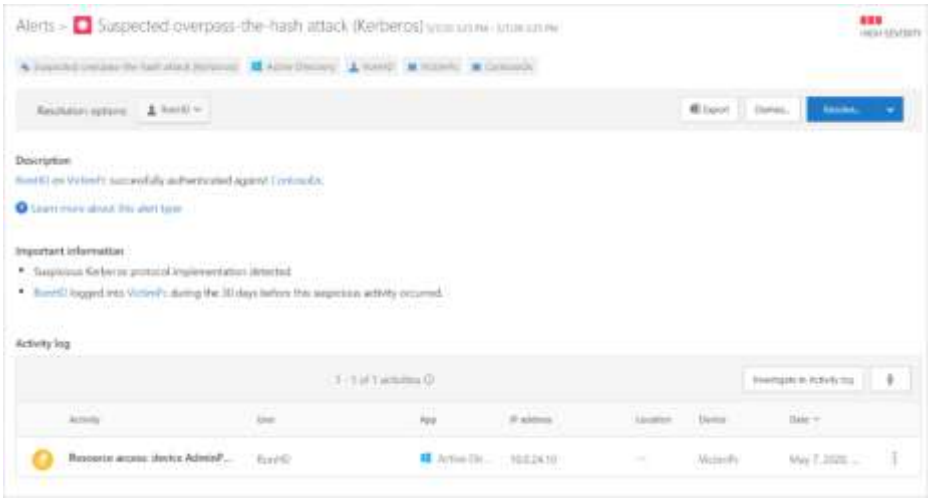
Within the alert, we can also find the activity log, which shows more information about the command that was run.



Back in the Alerts overview, we can see a more recent alert pointing to an overpass-the-hash attack.



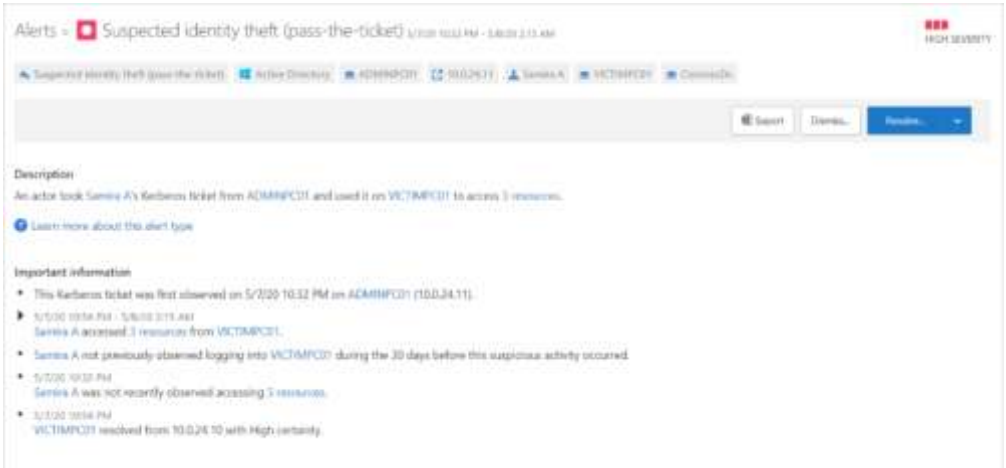
Opening the suspected overpass-the-hash-attack (Kerberos) alert, we see evidence that the user account was part of a lateral movement path.



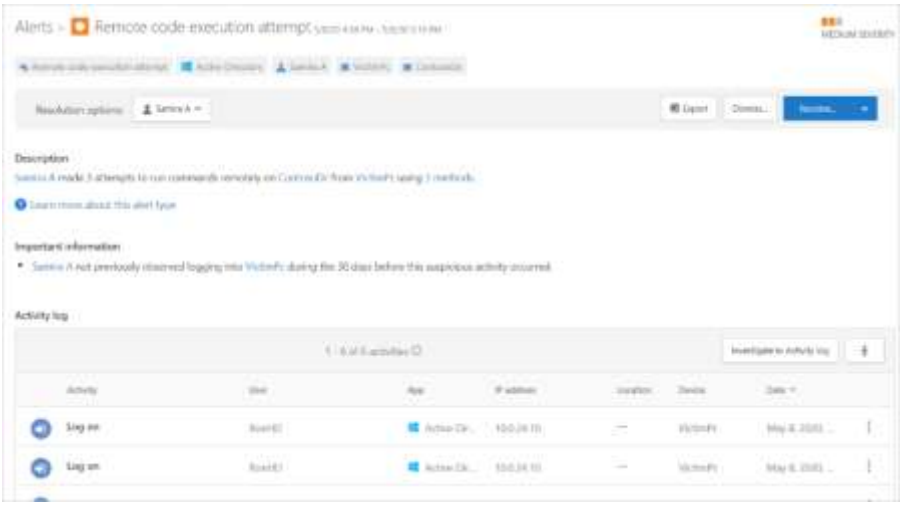
The next alert shows a Suspected identity theft (pass-the-ticket).



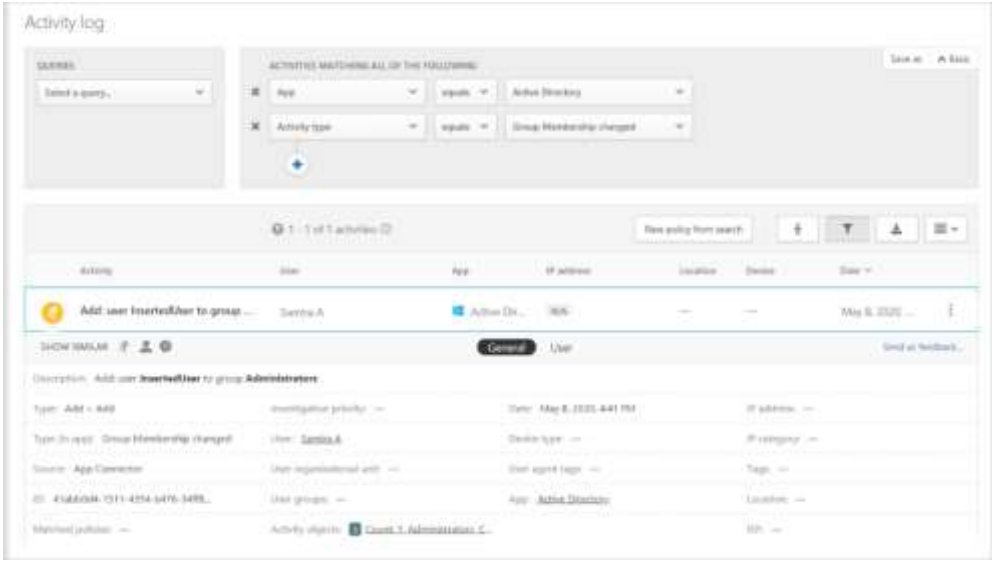
Microsoft Defender for Identity has detected theft of a ticket from a domain administrator to the infiltrated PC. The Microsoft Defender portal shows exactly which resources were accessed using the stolen tickets.



In the next alert, we see that the stolen credentials were used to run a remote command on the domain controller.



Looking into the Activity Log for the alert, we see that the command was to create a new user within the Administrators group.



From all the previous alerts, we suspect that an attacker has:

Infiltrated a PC.

Used the PC to determine IP addresses of other users' PCs, one of which belongs to a domain administrator.

Performed an overpass-the-hash attack by stealing the NTLM hash from another user who previously authenticated to the infiltrated PC to access any resource the user has permissions for. (In this case, local admin rights to IP addresses previously exposed)

Used the newly stolen credentials to gain access to the domain administrator's PC.

Used their access to the domain administrator's PC to steal the identity of the domain administrator.

Used the domain administrator's identity to access the domain controller, and created a new user account with domain administrative permissions.

With domain administrative permissions, the attacker has effectively compromised the environment. Now they're free to perform any number of attacks, such as a Skeleton Key attack.

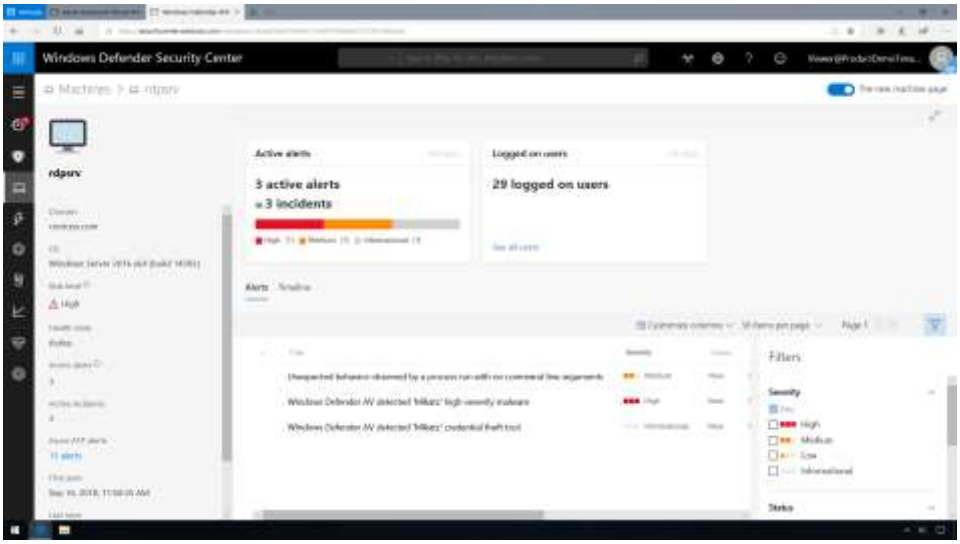
Integrate with other Microsoft tools

Microsoft Defender for Identity is a cloud-based security solution fully integrated with Microsoft Defender XDR. As a native component of the Microsoft Defender XDR platform, Defender for Identity contributes identity intelligence — including on-premises AD signals and Microsoft Entra ID signals — to correlated alerts and incidents shared across all Defender workloads in the unified Microsoft Defender portal.

This unified experience means that on-premises identity activities and cloud application activities appear together in the same alert queue and incident graph. Alerts from Defender for Identity, Microsoft Defender for Cloud Apps, and Defender for Endpoint are automatically correlated into incidents, giving you combined insights across your cloud and on-premises environments without any separate integration steps. The following screenshot shows Microsoft Defender for Identity reporting within the Microsoft Defender portal.



Microsoft Defender for Identity also works alongside Microsoft Defender for Endpoint within the unified platform. While Defender for Identity monitors the traffic on your domain controllers, Defender for Endpoint monitors your endpoints — together contributing their signals to the shared incident and alert queue in the Microsoft Defender portal. You can select any endpoint in the portal to view Defender for Identity alerts associated with that device.



Having this level of insight into system running processes allows an analyst to locate event sequences leading to a compromise of the network. In the screenshot below, there are high severity alerts pointing to malware being installed on the system.

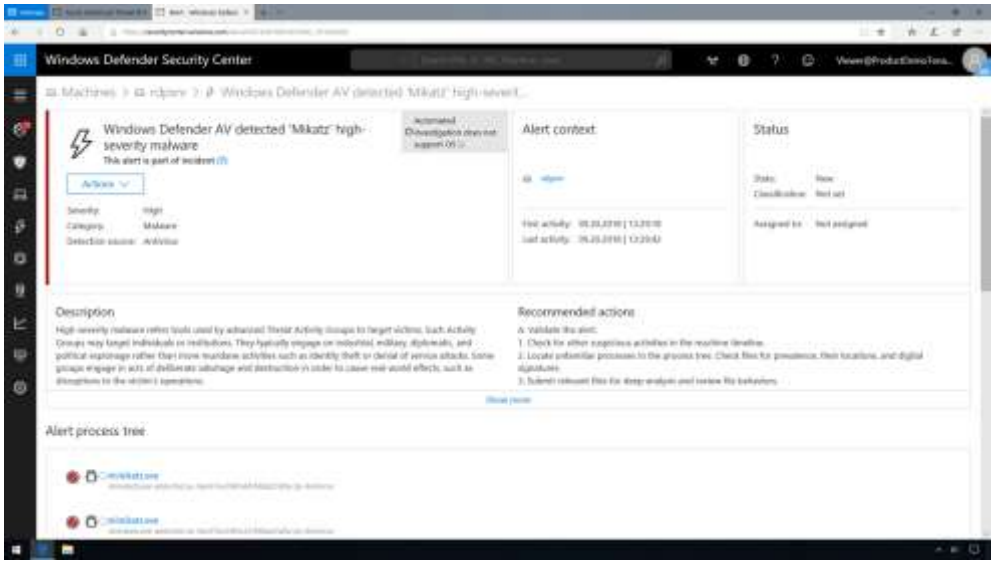
Other integrations

Microsoft Defender for Identity extends its protection to other identity sources and security platforms:

Privileged Access Management (PAM) platforms — Defender for Identity integrates with CyberArk, Delinea, and BeyondTrust to detect threats targeting privileged accounts managed by those platforms.

Okta — Defender for Identity can monitor Okta sign-ins and activity, enabling detection of suspicious identity events in hybrid environments that include cloud identity providers.

Microsoft Security Copilot — Identity insights from Defender for Identity flow into Microsoft Security Copilot, helping analysts triage and investigate incidents faster using natural language.



Clicking into the alert verifies that a Pass-The-Hash (PtH) attack occurred using the tool Mimikatz. Under actions for the alert, we can also review a timeline of events surrounding the credential theft.

